

CheckWise Route, Workflow, and Redirect Audit

Date: 2026-05-18

Branch: main

Commit audited: a34cd6e docs(reports): add §24 documenting R2 ? interactive list filters

Auditor: Codex

Purpose: Independent QA findings for Claude Code.

Executive Summary

The app is broadly navigable across admin, client, and provider shells, and the local stack ran successfully. Admin and client Reports after R1.1/R1.0.1/R2 are in good shape: preset galleries render, R2 filters work, and preset clicks open the shared editor inside the correct shell.

The two highest-priority findings are both workflow blockers: the activation cancel link lets a temporary-password user reach the provider portal without changing the password, and Provider Reports now shows provider-facing presets but cannot create a provider report in the current running database.

Recommendation: fix the P1 issues before continuing deeper Provider-first Reports work. The provider direction is right, but the current provider report creation path is not yet reliable end to end.

Ground Truth

- Initial repo path supplied by the environment was one level above the Git repo; the actual repo audited was /Users/josepablosamano/Desktop/Work ? LegalShelf/checkwise/CheckWise.
- git status at initial inspection was clean on main.
- During the audit, parallel source changes appeared outside the allowed Codex audit folder: backend/app/api/v1/reports.py, backend/app/services/report_service.py, backend/app/services/reports/templates.py, backend/tests/test_reports_presets.py, frontend/app/portal/reports/page.tsx. I did not edit those files.
- Final working tree includes only Codex-created report artifacts under docs/codex-route-workflow-audit/ plus the parallel source changes above.
- Local stack: frontend http://localhost:3000 and backend http://127.0.0.1:8000 both responded successfully.
- Verification: backend health OK, DB health OK, frontend typecheck passed, backend pytest passed 332 passed, 2 warnings.

Accounts Tested

Account Result

ada@legalshelf.mx / demo1234 Login PASS -> /admin/reviewer; admin shell and Reports PASS.
cliente.demo@checkwise.mx / ClienteDemo!2026 Login PASS -> /client/dashboard; client Reports PASS; internal-only reports hidden by API.
boss.demo@checkwise.mx / BossDemo!2026 Login PASS -> /portal/entra-a-tu-espacio; portal entry/dashboard/upload render; Provider Reports create FAIL.
proveedor.demo@checkwise.mx / CheckWiseDemo!2026 Login PASS -> /activate; activation form renders; cancel bypass FAIL.

Route Coverage Summary

- Meaningful frontend routes inventoried: 35.
- Passed/rendered or safely redirected: 29.
- Partial / needs specific data: 4.
- Failed core workflow: 2.
- Browser screenshots captured: see screenshots/ and browser_screenshots_index.json.

Detailed route data: route_inventory.csv.

Redirect Matrix

Reports Findings

Admin Reports

- /admin/reports uses shared ReportsListView.
- Six presets visible to admin: three internal and three client-facing. This is functionally allowed but the section label ?Plantillas operativas? may under-explain why client-facing templates are present.
- Status filter, audience filter, search, clear filters, and template click were browser-verified.
- Preset click opened /admin/reports/22d71263-e3eb-4efc-81f2-32bbc2a58d06 in AdminShell with AI, Copilot, Print, and Save controls.

Client Reports

- /client/reports uses shared ReportsListView.
- Three client-facing presets visible.
- Audience filter correctly hidden; only one status select present.
- API returned only client_facing reports for client account.
- Preset click opened /client/reports/41d0ad6e-cd06-4cef-adaf-41034b026629 in ClientShell.

Provider Reports

- Parallel changes migrated /portal/reports to shared ReportsListView and exposed three vendor-facing presets.
- The list now has R2-style search + status filter and no audience filter, which aligns with the product direction.
- However, clicking ?Usar plantilla? fails with {"detail": "User has no organization memberships."} in the current running DB. Provider-first Reports should not continue until this is fixed or backfilled.

Provider Priority Assessment

What works:

- Provider login lands in /portal/entra-a-tu-espacio.
- Workspace confirmation is clear and provider-specific.
- Dashboard renders operational next actions.
- Upload route renders and is discoverable.
- Provider Reports now has the right conceptual shape: provider-facing presets, list filters, shared editor target.

What is confusing or blocked:

- Provider report creation fails, so the most important next provider workflow cannot complete.
- Boss demo is API-reported as expediente_status=complete, but the dashboard still surfaced limited/initial-expediente messaging during browser verification.
- Direct provider report/print checks are not meaningful until provider-owned reports can be created or seeded in the running DB.

Security and Role Safety

- API role safety passed for normal role checks: client/provider receive 403 on admin/reviewer/client endpoints where appropriate.
- Client Reports API returned only client_facing reports.
- Provider Reports API returned provider presets after parallel changes, but provider create failed due missing organization membership/scope.
- Activation has a practical safety issue: a user with must_change_password=true can cancel to /login and be routed into the provider portal with the still-valid temporary JWT.

Issues by Severity

CW-AUD-P1-02 P1 /portal/reports Provider presets are visible but unusable in the current running DB Backfill/create owning org membership/scope for existing provider workspaces, or make create_report derive organization/client/vendor from ProviderWorkspace ownership at runtime.

CW-AUD-P2-01 P2 /portal/reports/[id]/print Provider own print route cannot be verified Retest once CW-AUD-P1-02 is fixed.

CW-AUD-P2-02 P2 /portal/dashboard Provider dashboard copy can imply incomplete expediente for a complete demo user Confirm whether dashboard uses onboarding slot counts vs session completion; align copy/state for completed provider.

CW-AUD-P3-01 P3 /admin/login, shells Legacy admin-login double-hop remains Change shell unauth redirects/logout destinations to /login when legacy page is no longer needed.

CW-AUD-P3-02 P3 Admin/client shell header Logout button accessible name was inconsistent in automation snapshots Ensure SignOut button keeps text or aria-label outside responsive-hidden spans.

Issue Details

CW-AUD-P1-01 ? P1

- Route/page: /activate
- Description: Activation cancel bypasses forced password change
- Expected: A temp-password user should not enter portal until password is changed or session is cleared.
- Actual: Clicking ?Cancelar e iniciar sesión de nuevo? sends user to /login, whose boot redirect uses stored JWT and lands in /portal/entra-a-tu-espacio.
- Evidence: Screenshot 42; browser_interactions activation observation.
- Suggested fix: Clear admin session on cancel; also enforce must_change_password in route guards/API for protected surfaces.
- Owner recommendation: Claude Code

CW-AUD-P1-02 ? P1

- Route/page: /portal/reports
- Description: Provider presets are visible but unusable in the current running DB
- Expected: Provider should create a vendor_facing report from preset and open /portal/reports/[id].
- Actual: POST /api/v1/reports/from-preset as boss.demo returns 403 {"detail":"User has no organization memberships."}; browser stays on list with warning.
- Evidence: Screenshot 36; curl API probe; browser_interactions provider error.
- Suggested fix: Backfill/create owning org membership/scope for existing provider workspaces, or make create_report derive organization/client/vendor from ProviderWorkspace ownership at runtime.
- Owner recommendation: Claude Code

CW-AUD-P2-01 ? P2

- Route/page: /portal/reports/[id]/print
- Description: Provider own print route cannot be verified
- Expected: A provider-created report should open printable view.
- Actual: Provider cannot create/open own report; direct non-owned id shows not-available/loading state.
- Evidence: Browser route smoke.
- Suggested fix: Retest once CW-AUD-P1-02 is fixed.
- Owner recommendation: Claude Code

CW-AUD-P2-02 ? P2

- Route/page: /portal/dashboard
- Description: Provider dashboard copy can imply incomplete expediente for a complete demo user
- Expected: Boss demo is documented/API-reported as expediente_status=complete.
- Actual: Dashboard still surfaced ?Tu dashboard estÆ limitado?/initial-expediente tasks in

CW-AUD-P3-01 ? P3

- Route/page: /admin/login, shells
- Description: Legacy admin-login double-hop remains
- Expected: Protected routes should route directly to the unified login.
- Actual: Logged-out admin/client protected routes bounce through /admin/login then /login; functional but noisy.
- Evidence: Source + browser redirect.
- Suggested fix: Change shell unauth redirects/logout destinations to /login when legacy page is no longer needed.
- Owner recommendation: Claude Code

CW-AUD-P3-02 ? P3

- Route/page: Admin/client shell header
- Description: Logout button accessible name was inconsistent in automation snapshots
- Expected: Buttons should have stable accessible labels across breakpoints.
- Actual: Some header snapshots exposed a blank button plus menu button; click by accessible name was unreliable, position click worked.
- Evidence: Browser snapshots and interaction notes.
- Suggested fix: Ensure SignOut button keeps text or aria-label outside responsive-hidden spans.
- Owner recommendation: Claude Code

Claude Action Items

1. Fix activation cancel/session handling so must_change_password users cannot enter protected provider routes before setting a permanent password.
2. Fix Provider Reports creation for existing and fresh provider workspaces: derive or backfill organization/client/vendor scope for workspace owners.
3. Retest /portal/reports preset click, generated provider editor shell, and print route after the provider-scope fix.
4. Reconcile boss demo dashboard messaging with expediente_status=complete.
5. Clean up legacy /admin/login double-hop and stabilize logout button accessible names.

Commands Run

- git status --short && git status --branch --short
- git branch --show-current
- git log --oneline -10
- git diff --stat
- curl http://127.0.0.1:8000/api/v1/health
- curl http://127.0.0.1:8000/api/v1/health/db
- Browser UI login and route checks for admin, client, provider, activation.
- API role/preset/report probes via Python urllib.
- backend/.venv/bin/pytest -q -> 332 passed, 2 warnings.
- frontend/node_modules/.bin/tsc --noEmit -> passed.

Limitations

- Claude Code appeared to modify Provider Reports while this audit was running. Findings distinguish initial static observations from the final dirty working-tree behavior where possible.
- I did not submit the final activation password-change form, to avoid mutating the seeded activation account.
- Browser screenshots 01-24 include some early timing captures; robust evidence screenshots are 26 onward, especially 32, 36, 37-42.
- Provider-owned report editor/print route could not be fully verified because provider report creation is currently blocked.

Appendix